

## PASTA Analysis

| Stages                                            | Sneaker company                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|---------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>I. Define business and security objectives</b> | <ul style="list-style-type: none"><li>• <i>Users can create member profiles internally or by connecting external accounts which contain sensitive PII.</i></li><li>• <i>The app will need to process payment transactions between users.</i></li><li>• <i>All data privacy regulations, such as PCI-DSS, will need to be considered.</i></li></ul>                                                                                                                                                                                                                                                                                                                                                                                                    |
| <b>II. Define the technical scope</b>             | <p>List of technologies used by the application:</p> <ul style="list-style-type: none"><li>• <i>Application programming interface (API)</i></li><li>• <i>Public key infrastructure (PKI)</i></li><li>• <i>SHA-256</i></li><li>• <i>SQL</i></li></ul> <p><i>APIs facilitate the exchange of data between customers, partners, and employees, so they should be prioritized. They handle a lot of sensitive data as they connect various users and systems. Details such as which APIs are being used should be considered before prioritizing technology. These are more prone to security vulnerabilities because there's a larger attack surface. SQL injections are a serious threat and can lead to data breaches if not handled properly.</i></p> |
| <b>III. Decompose application</b>                 | <p><a href="#">Sample data flow diagram</a></p> <p>Users will use the product search process to query the database to find product listings they are interested in.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| <b>IV. Threat analysis</b>                        | <ul style="list-style-type: none"><li>• <i>Injection</i></li><li>• <i>Session hijacking</i></li></ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| <b>V. Vulnerability analysis</b>                  | <ul style="list-style-type: none"><li>• <i>Lack of prepared statements</i></li><li>• <i>Broken API token</i></li></ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| <b>VI. Attack modeling</b>                        | <p><a href="#">Sample attack tree diagram</a></p> <p>Attackers can use SQL injections to obtain sensitive information such as user passwords and credentials.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |

|                                      |                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>VII. Risk analysis and impact</b> | <ul style="list-style-type: none"><li>• Input sanitization</li><li>• Predefined statements to prevent SQL injections.</li><li>• Automatic updates and patching for API's.</li><li>• OAuth to prevent session hijacking.</li><li>• SHA-256</li><li>• <i>Incident response procedures</i></li><li>• <i>Password policy</i></li><li>• <i>Principle of least privilege</i></li></ul> |
|--------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|